Authentication - Part 1: JWT

WU YANLAN (Viclant) | Student ID: 2023905420
EPITA Computer Security | Prepared 31 October 2026

1. Aim

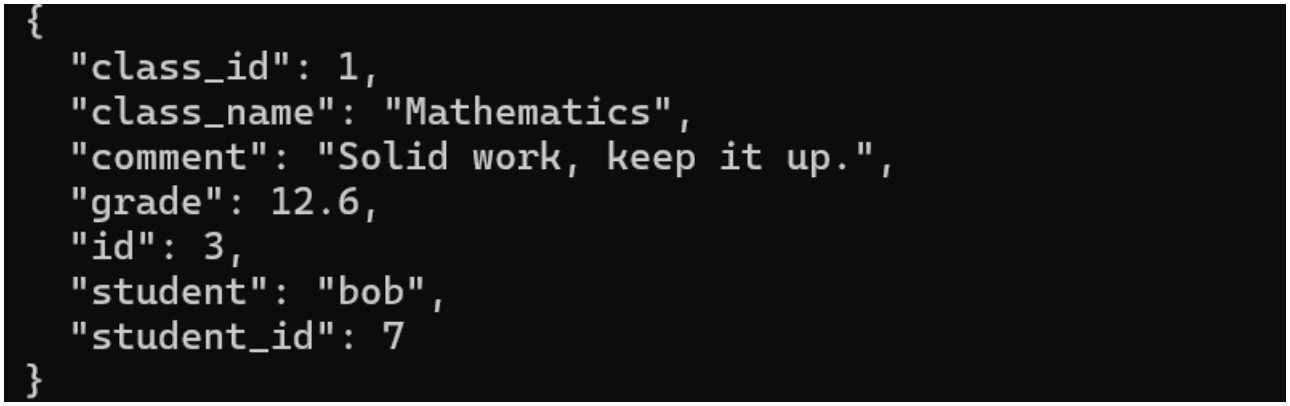
Understand why an unsigned JWT can expose another student's grade in the local NotesApp lab.

2. Before the exercise

Prediction: Not recorded in the saved notes.

3. Saved result

The local Part 1 script uses a teacher identity claim in an unsigned token. The saved screenshot shows a record for bob: Mathematics, grade 12.6, with the comment "Solid work, keep it up." The record ID is 3 and the student ID is 7.



```
{
  "class_id": 1,
  "class_name": "Mathematics",
  "comment": "Solid work, keep it up.",
  "grade": 12.6,
  "id": 3,
  "student": "bob",
  "student_id": 7
}
```


Figure 1. Response excerpt from the saved screenshot. The response is unchanged.

4. Explanation

A JWT contains claims about a user. Decoding those claims does not prove who created them. In the reviewed NotesApp code, the server can accept unsigned claims as the request identity. The grade API also does not check who owns the requested record. This explains why another student's grade can be exposed.

5. Conclusion

I learned that the server must verify a token before trusting its identity or role. For this API, it should reject unsigned tokens and check whether the user is allowed to read the grade. The implementation of the JWT fixes belongs to the Class 7 lab.

This write-up uses the saved result and a code review; the lab was not rerun during preparation.

References

Course: Authentication Sessions JWT MFA.pdf, Part 1, PDF pages 14-17. Code: NotesApp web/app.py at e4a88a5.

NotesApp source | Course fixes: supplied deck, PDF page 24.